Reflection — SecureCorp Security Assessment Engagement

Task 4.4 | Junior Security Consultant (Student) | W4-T4.4-reflection

1. You attacked SecureCorp, then investigated it. What did the attacker know that the defender didn't?

As the attacker, I had perfect knowledge of my own actions: I knew my source IP (10.10.10.5), the exact service I was targeting, and the exact moment I ran each attack, because I was the one typing the commands. None of that was available to me once I switched to the defender's chair in Week 3.

As the defender, I started with nothing but a pile of raw logs and no prior context. I had to grep the logs for my own IP just to confirm an attack had even happened, read through timestamps to reconstruct a timeline, and cross-check everything against my own Week 2 attack notes to separate my testing from anything else. The attacker's advantage isn't skill — it's that they already know the answer to every question the defender has to go digging for.

2. Which of your attacks was hardest to detect, and why?

The DVWA-based attacks — SQL injection, reflected XSS, and OS command injection — were by far the hardest to detect. But the reason had nothing to do with how I executed them; I wasn't using any stealth technique or trying to evade detection. They were undetectable for a much simpler reason: no Apache/DVWA access or error log was ever being collected on the log box in the first place.

This was a structural blind spot, not a skill gap on my part as the attacker. I confirmed this directly in Task 3.2 — I checked every log file that existed on the log box, and the entire web layer simply wasn't represented anywhere. It's a useful lesson: the most dangerous attacks aren't always the cleverest ones, they're the ones that happen to land in a part of the system nobody is watching.

3. What did the seeded incident (Task 3.3) teach you that your own attacks didn't?

My own Week 2 attacks all came from one predictable place — 10.10.10.5, over the network, using known tools like Hydra and Metasploit. The seeded incident looked completely different, and that difference is what taught me the most.

The detail that gave it away was the TTY=tty1 field in sudo.log — it showed the session originated from the local console, not a remote login like every one of my own Week 2 activities. I had to notice that one field buried among routine log noise, then cross-check the timestamps against my own attack log to be sure it wasn't something I'd simply forgotten doing.

That process is the real lesson of this engagement: detection isn't about finding something obviously malicious — it's about noticing when something doesn't fit the pattern you'd expect, and having the discipline to verify it rather than assume. A real SOC analyst doesn't get a banner that says "this one's the intrusion." They get a field like TTY=tty1 sitting quietly in a log, and it's on them to notice it.